

# Respostas Modelo (com Variações)

---

Exame CA 2024/2025 — LEI / LSIRC

Diferentes formas válidas de responder às perguntas de desenvolvimento

## Parte I

### 1.1. A aplicação de métodos criptográficos à mensagem original gera um \_\_\_\_\_.

**Resposta Única: Criptograma** (ou Texto Cifrado).

### 1.2. Análise de frequência ou força bruta para AES? Justifique.

**Exemplo 1** (Curta e Direta): **Força bruta.** O algoritmo AES é uma cifra forte que não deixa padrões no texto cifrado, tornando a análise de frequência inútil.

**Exemplo 2** (Completa/Detalhada): **Força bruta.** A análise de frequência baseia-se na identificação de padrões da linguagem original no criptograma. Como o AES destrói as propriedades estatísticas da linguagem através de difusão e confusão (gerando um output pseudoaleatório uniforme), a única forma teórica de quebrar a cifra é testar exaustivamente todas as chaves possíveis através de um ataque de **força bruta**.

**Exemplo 3** (Em Tópicos):

- **Mecanismo:** Força bruta.
- **Justificação:** O AES distribui os dados de forma pseudoaleatória. Não há padrões estatísticos a explorar, logo a análise de frequência não funciona. Resta tentar todas as chaves.

### 2.1. Tamanho mínimo da chave no "One Time Pad".

**Resposta Única: Igual ou superior ao tamanho da mensagem** (para garantir o sigilo perfeito / perfect secrecy).

### 3.1. Modo CTR — identificação e vantagens.

**Exemplo 1** (Direta): **Modo CTR (Counter).** A principal vantagem é permitir que a cifra e decifra sejam processadas em **paralelo**, tornando-o muito mais rápido e eficiente.

**Exemplo 2** (Completa): Modo CTR. As vantagens são:

- Transforma uma cifra de blocos numa cifra de fluxo (stream cipher).
- Permite o processamento em paralelo (ao contrário do modo CBC).
- Tem acesso aleatório direto a partes do ficheiro sem ter de decifrar tudo.
- Não necessita de padding.

### 3.2. Algoritmo de padding para resultado "... 03 04 05".

**Resposta Única: ISO 10126-2** (adiciona bytes aleatórios seguidos de um byte final com o tamanho do padding).

## 4. Criptografia Assimétrica (V/F)

**4.1. Verdadeiro** (para encriptar usa-se a chave pública do destinatário).

**4.2. Falso** (para decifrar usa-se a chave privada do próprio).

**4.3. Verdadeiro** (a chave pública do assinante valida a assinatura feita com a chave privada dele).

### 5.1. O que é necessário para validar uma assinatura digital (RSA)?

**Exemplo 1** (Tópicos):

- 1) Documento original;
- 2) Assinatura digital gerada;
- 3) Chave pública de quem assinou;
- 4) Conhecimento do algoritmo de hash utilizado.

**Exemplo 2** (Texto corrido): Para validar, precisamos do documento em claro e da respetiva **assinatura digital** anexada. Precisamos também da **chave pública do emissor** para decifrar a assinatura e obter o hash original, e saber qual o **algoritmo de hash** a aplicar à mensagem em claro para compararmos ambos os valores.

### 5.2. Opção mais segura? Justifique!

- a) SHA-1 with RSA 4096 bits
- b) SHA-2 with RSA 2048 bits**
- c) SHA-3 with RSA 512 bits
- d) SHA-4 with RSA 16384 bits

**Exemplo 1** (Curta): **Opção b)** (SHA-2 com RSA 2048). O SHA-1 já tem colisões conhecidas, as chaves RSA de 512 bits já foram quebradas, e o SHA-4 não existe. A opção b) usa algoritmos e tamanhos recomendados e seguros hoje em dia.

**Exemplo 2** (Completa): **Opção b)**. Justificação por eliminação: a) usa SHA-1, obsoleto por colisões; c) usa RSA 512 bits, computacionalmente quebrável; d) refere SHA-4, que não é um standard existente. **SHA-2 + RSA 2048** é a norma segura atual da indústria.

### 5.3. O MAC permite assegurar o não repúdio? Porquê?

**Exemplo 1** (Direta): **Não**. O MAC usa criptografia simétrica. Como emissor e recetor partilham a mesma chave, qualquer um deles pode ter gerado o MAC, impossibilitando provar a terceiros quem foi o autor.

**Exemplo 2** (Completa): **Não garante o não repúdio**. O não repúdio significa que o autor não pode negar a autoria. Como o MAC depende de uma chave secreta partilhada, o servidor também possui a chave e pode gerar mensagens válidas. Só a **assinatura digital assimétrica** resolve este problema, porque a chave privada é exclusiva de quem assina.

### 6.1. Principal objetivo do protocolo de estabelecimento de sessão.

**Exemplo 1:** Acordar uma **chave de sessão simétrica** (secreta e temporária) de forma segura entre duas entidades para garantir a confidencialidade das mensagens seguintes.

**Exemplo 2:** O objetivo é que duas partes consigam partilhar ou derivar uma **chave secreta e temporária** através de um meio inseguro, assegurando a autenticação das partes. Essa chave será depois usada em algoritmos simétricos (muito mais rápidos) para encriptar os dados da sessão (ex: TLS).

## 7. Criptografia em Java

**7.1.** Devolve um objeto **SecretKey**.

**7.2.** Pode ser utilizado em criptografia **Assimétrica** (guarda **PublicKey** e **PrivateKey**).

**7.3.** O nome do **algoritmo** (ex: "HmacSHA256").

**7.4.** Um **array de bytes** (**byte[]**).

## Parte II

### 8.1. Principal utilização dos dispositivos criptográficos seguros.

**Exemplo 1** (Curta): **Guardar chaves privadas de forma inviolável** e executar operações criptográficas localmente (ex: assinar documentos).

**Exemplo 2** (Completa): A principal utilização é o **armazenamento seguro das chaves privadas e certificados**. Garantem que a chave privada nunca sai do hardware, sendo as operações de assinatura processadas no próprio chip do dispositivo (ex: Smartcard, HSM, eID), impedindo o roubo das chaves por malware.

## 9. Certificados Digitais

9.1. A relação entre uma **identidade (dono)** e a sua respetiva **Chave Pública**.

9.2. O campo **Serial Number (Número de Série)**.

9.3. A **Entidade Certificadora / CA (Certificate Authority)**.

### 10.1. Documentos/políticas publicados pelas Entidades Certificadoras.

**Resposta Única:** **DPC (Declaração de Práticas de Certificação / CPS)** e a **PC (Política de Certificação)**.

### 11.1. Como é obtida a CRL pelas aplicações?

**Resposta Única:** Através da leitura da extensão CDP (CRL Distribution Point) presente no próprio certificado, acedendo de seguida a um servidor HTTP ou LDAP aí indicado para fazer o download da lista.

### 12.1. Num serviço web é melhor utilizar CRL ou OCSP? Porquê?

**Exemplo 1** (Curta): **OCSP** é melhor porque é mais leve e rápido. Permite consultar o estado de um único certificado em tempo real, sem ter de fazer o download da lista (CRL) inteira que consome largura de banda.

**Exemplo 2** (Completa): **O protocolo OCSP**. Enquanto que a CRL exige o download regular de um ficheiro extenso com todos os certificados revogados, o OCSP funciona por pedido/resposta para validar apenas o certificado específico que está a ser usado. Isso poupa largura de banda e garante a validação do estado em **tempo real**.

### 13.1. Que objetos usar ao invocar um serviço de Timestamp?

**Resposta Única:** **O Hash (resumo da mensagem) do documento**. Não se envia o documento completo.

## 14. Standards (PKCS)

14.1. O standard **PKCS#11 (Cryptoki)**.

14.2. Contém um **selo temporal (Timestamp)**, garantindo a data e hora oficial em que a assinatura decorreu.

### 15.1. HSTS — aumenta ou diminui a compatibilidade? Porquê?

**Exemplo 1** (Curta): **Diminui a compatibilidade.** O HSTS obriga ao uso exclusivo de HTTPS. Sistemas legacy ou browsers sem suporte para HSTS falharão a ligação se tentarem usar HTTP não encriptado.

**Exemplo 2** (Completa): **A compatibilidade diminui.** O cabeçalho HSTS instrui o browser a comunicar apenas por canais seguros (HTTPS). Aplicações antigas, sistemas sem certificados válidos ou que forcem ligações HTTP puro não conseguirão comunicar com o servidor — sacrifica-se compatibilidade em prol de maior segurança.